

👉 ■ Authentication & Authorization (Backend Notes)

Style: Handwritten • Image-like • Exam Ready

1) Authentication

Authentication means checking **who the user is**.

Example: Email + Password, OTP, Google Login

2) Authorization

Authorization means checking **what the user can do**.

Example: Admin can delete users, User can view profile

3) Authentication vs Authorization

Authentication	Authorization
Who are you?	What can you do?
Login process	Permission process
First step	Second step

4) Email Verification using OTP

OTP = One Time Password

Flow:

1. User registers with email
2. Backend generates OTP
3. OTP is sent to user's email
4. User enters OTP
5. Backend verifies OTP
6. Account is verified

5) JWT (JSON Web Token)

JWT is used to keep user logged in securely.

Structure: HEADER . PAYLOAD . SIGNATURE

6) Middleware

Middleware protects routes by checking token and role.

7) Common Errors

401 → Unauthorized (Not logged in)

403 → Forbidden (No permission)

✓ Authentication comes before Authorization

✓ OTP is used for email verification